Slice 1 — Accounts, companies, roles

Built: 22 October 2026 · **Status:** code complete, 14 automated tests passing. Your live test of 23 October was cut short by a fault in the local database (section 9, fixed the same evening); runs 5, 6 and 7 of the test road are still to finish. **Roadmap:** slice 1 of 12, the spine. Nothing else exists yet, on purpose.

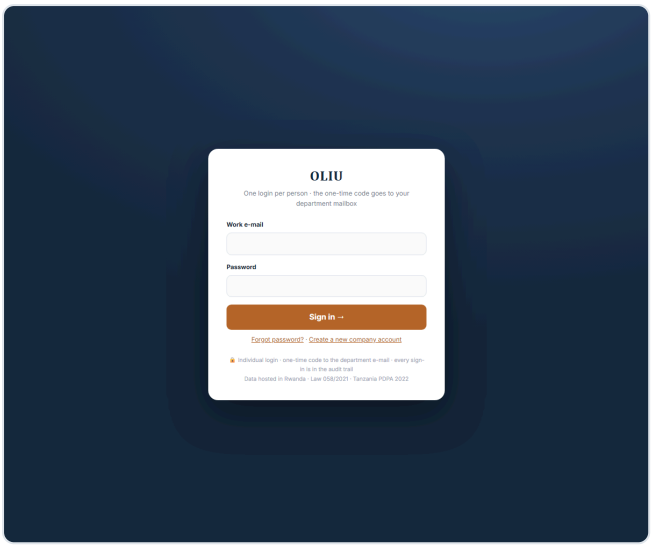
This note is written for you, not for a developer. It says what exists, how it works, how to try it, what was tested, what was left out, and the questions for you.

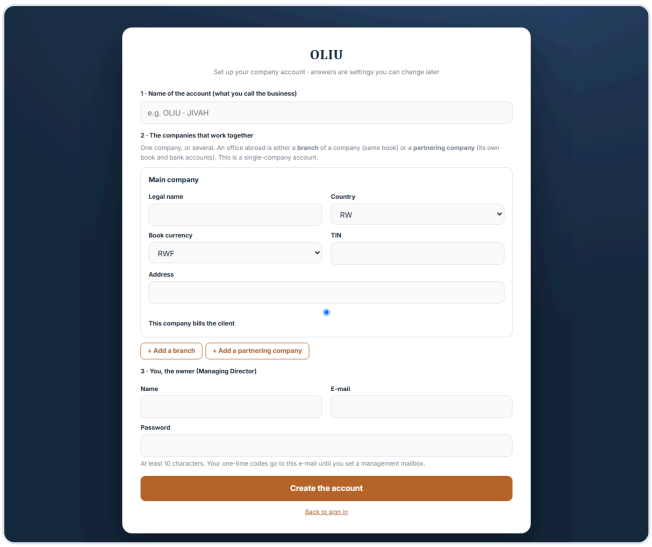
---

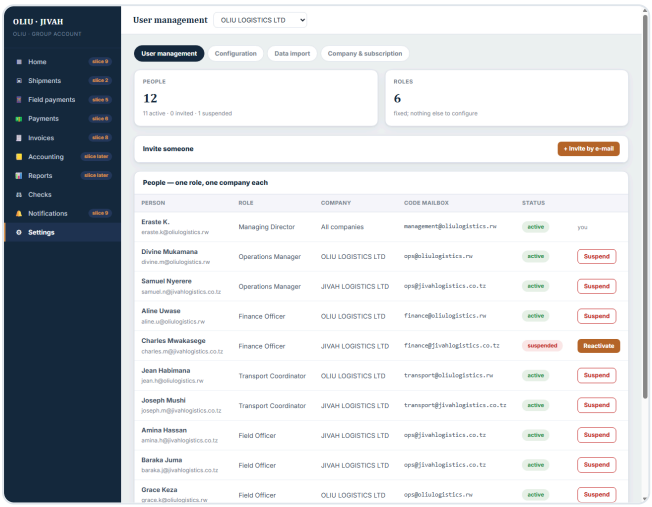
1. What exists now, in one picture

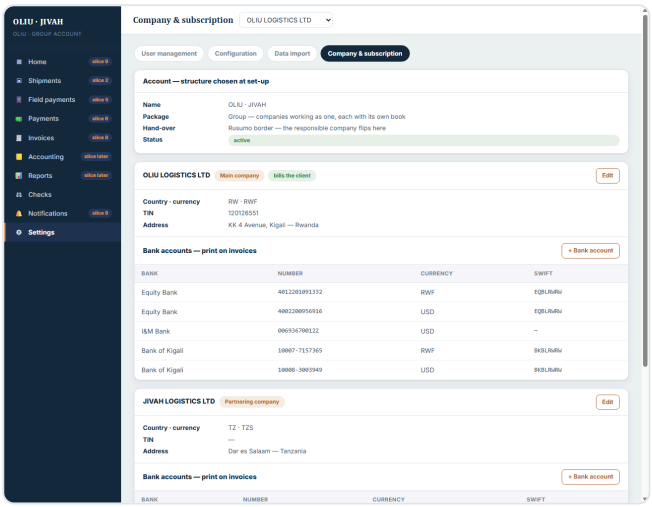
```
 browser (Nuxt, port 3000)  ──/api/*──▶  API (Express, port 3001)  ──▶  PostgreSQL
   login · one-time code                 checks who you are and          Account
   set-up questions                      what you may touch on           Company · BankAccount
   Settings → User management            EVERY request                   User · Session · OtpChallenge · ActionToken
   Settings → Company & subscription                                     FeatureSwitch
   Checks → Audit trail                                                  AuditEvent (append-only)
```

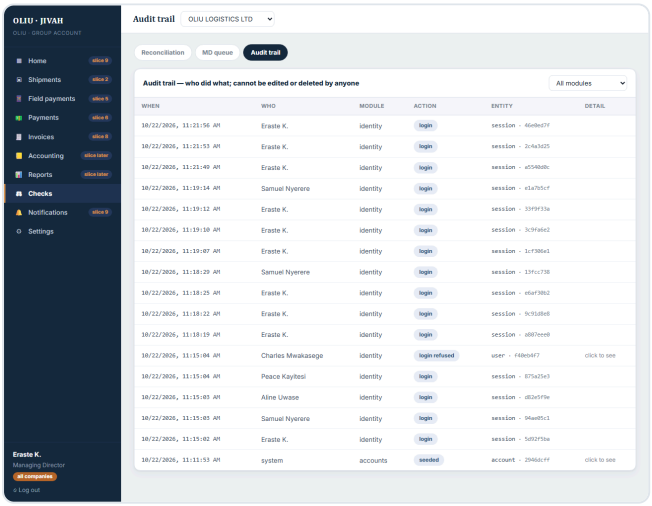
Three screens work. Every other menu is there, in the right place, and says which slice brings it.

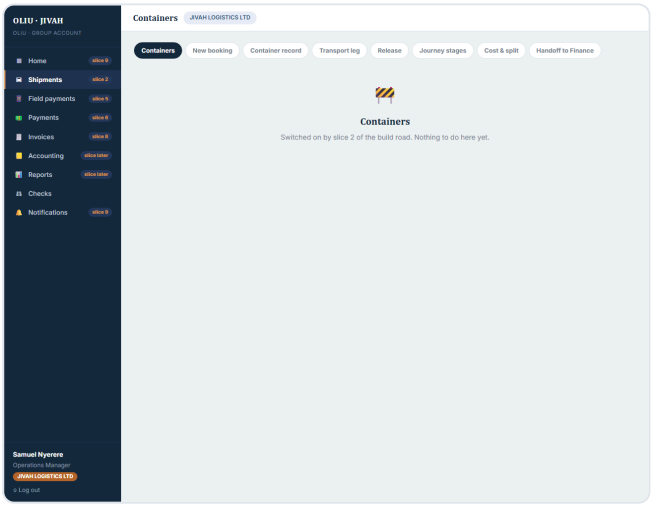

OLIU
One login per person · the one-time code goes to your department mailbox
Work e-mail
Password
Sign in →
Forgot password? · Create a new company account
Individual login · one-time code to the department e-mail · every sign-in is in the audit trail
Data hosted in Rwanda · Law 058/2021 · Tanzania POPA 2022


OLIU
Set up your company account · answers are settings you can change later
1 · Name of the account (what you call the business)
e.g. OLIU · JIVAH
2 · The companies that work together
One company, or several. An office abroad is either a branch of a company (same book) or a partnering company (its own book and bank accounts). This is a single-company account.
Main company
Legal name
Country
RW
Book currency
RWF
TIN
Address
This company bills the client
+ Add a branch
+ Add a partnering company
3 · You, the owner (Managing Director)
Name
E-mail
Password
At least 10 characters. Your one-time codes go to this e-mail until you set a management mailbox.
Create the account
Back to sign in


OLIU · JIVAH
OLIU · GROUP ACCOUNT
Home
Shipments
Field payments
Payments
Invoices
Accounting
Reports
Checks
Notifications
Settings
User management
OLIU LOGISTICS LTD
User management
Configuration
Data import
Company & subscription
PEOPLE
12
11 active · 0 invited · 1 suspended
ROLES
6
fixed; nothing else to configure
Invite someone
+ Invite by e-mail
People — one role, one company each
PERSON
ROLE
COMPANY
CODE MAILBOX
STATUS
Eraste K.
Managing Director
All companies
management@oliulogistics.rw
active
you
Divine Mukamana
Operations Manager
OLIU LOGISTICS LTD
ops@oliulogistics.rw
active
Suspend
Samuel Nyerere
Operations Manager
JIVAH LOGISTICS LTD
ops@jivahlogistics.co.tz
active
Suspend
Aline Uwase
Finance Officer
OLIU LOGISTICS LTD
finance@oliulogistics.rw
active
Suspend
Charles Mwakasege
Finance Officer
JIVAH LOGISTICS LTD
finance@jivahlogistics.co.tz
suspended
Reactivate
Jean Habimana
Transport Coordinator
OLIU LOGISTICS LTD
transport@oliulogistics.rw
active
Suspend
Joseph Mushi
Transport Coordinator
JIVAH LOGISTICS LTD
transport@jivahlogistics.co.tz
active
Suspend
Amina Hassan
Field Officer
JIVAH LOGISTICS LTD
ops@jivahlogistics.co.tz
active
Suspend
Baraka Juma
Field Officer
JIVAH LOGISTICS LTD
ops@jivahlogistics.co.tz
active
Suspend
Grace Keza
Field Officer
OLIU LOGISTICS LTD
ops@oliulogistics.rw
active
Suspend


OLIU · JIVAH
OLIU · GROUP ACCOUNT
Home
Shipments
Field payments
Payments
Invoices
Accounting
Reports
Checks
Notifications
Settings
Company & subscription
OLIU LOGISTICS LTD
User management
Configuration
Data import
Company & subscription
Account — structure chosen at set-up
Name
OLIU · JIVAH
Package
Group — companies working as one, each with its own book
Hand-over
Rusumo border — the responsible company flips here
Status
active
OLIU LOGISTICS LTD
Main company
bills the client
Edit
Country · currency
RW · RWF
TIN
120126551
Address
KK 4 Avenue, Kigali — Rwanda
Bank accounts — print on invoices
+ Bank account
BANK
NUMBER
CURRENCY
SWIFT
Equity Bank
4011201091332
RWF
EQBLRWRW
Equity Bank
4002200056916
USD
EQBLRWRW
I&M Bank
0069367001 22
USD
–
Bank of Kigali
10007-7157365
RWF
BKBLRWRW
Bank of Kigali
10008-3003949
USD
BKBLRWRW
JIVAH LOGISTICS LTD
Partnering company
Edit
Country · currency
TZ · TZS
TIN
—
Address
Dar es Salaam — Tanzania
Bank accounts — print on invoices
+ Bank account
BANK
NUMBER
CURRENCY
SWIFT


OLIU · JIVAH
OLIU · GROUP ACCOUNT
Home
Shipments
Field payments
Payments
Invoices
Accounting
Reports
Checks
Notifications
Settings
Audit trail
OLIU LOGISTICS LTD
Reconciliation
MD queue
Audit trail
Audit trail — who did what; cannot be edited or deleted by anyone
All modules
WHEN
WHO
MODULE
ACTION
ENTITY
DETAIL
10/22/2026, 11:21:56 AM
Eraste K.
identity
login
session · 46e8ed7f
10/22/2026, 11:21:53 AM
Eraste K.
identity
login
session · 2c4a3d25
10/22/2026, 11:21:40 AM
Eraste K.
identity
login
session · a5540d0c
10/22/2026, 11:19:14 AM
Samuel Nyerere
identity
login
session · e1a7b5cf
10/22/2026, 11:19:12 AM
Eraste K.
identity
login
session · 33f9f33a
10/22/2026, 11:19:10 AM
Eraste K.
identity
login
session · 3c9fa6e2
10/22/2026, 11:19:07 AM
Eraste K.
identity
login
session · 1cf306e1
10/22/2026, 11:18:29 AM
Samuel Nyerere
identity
login
session · 13fcc738
10/22/2026, 11:18:25 AM
Eraste K.
identity
login
session · e6af38b2
10/22/2026, 11:18:22 AM
Eraste K.
identity
login
session · 9c91d8e8
10/22/2026, 11:18:19 AM
Eraste K.
identity
login
session · b807eee0
10/22/2026, 11:15:04 AM
Charles Mwakasege
identity
login refused
user · f40eb4f7
click to see
10/22/2026, 11:15:04 AM
Peace Kayitesi
identity
login
session · 8754a15e3
10/22/2026, 11:15:03 AM
Aline Uwase
identity
login
session · d82e5f9e
10/22/2026, 11:15:03 AM
Samuel Nyerere
identity
login
session · 94aa05c1
10/22/2026, 11:15:02 AM
Eraste K.
identity
login
session · 5d92f5ba
10/22/2026, 11:11:53 AM
system
accounts
seeded
account · 29468cff
click to see
Eraste K.
Managing Director
all companies
Log out


OLIU · JIVAH
OLIU · GROUP ACCOUNT
Home
Shipments
Field payments
Payments
Invoices
Accounting
Reports
Checks
Notifications
Containers
JIVAH LOGISTICS LTD
Containers
New booking
Container record
Transport leg
Release
Journey stages
Cost & split
Handoff to Finance
Containers
Switched on by slice 2 of the build road. Nothing to do here yet.
Samuel Nyerere
Operations Manager
JIVAH LOGISTICS LTD
Log out

2. The rules this slice makes true

RULE	WHERE IT LIVES	HOW YOU CAN SEE IT
One login per person, one role, in one company or all	`User` table: `role`, `companyId` (null = all)	User management: each person's row
The one-time code goes to a **department mailbox**, not a personal inbox	`User.otpMailbox`	Login step 2 names the mailbox
A person sees only their company's side	`middleware/auth.ts` builds a *scope* from the session; every query filters by it	Sign in as Samuel (JIVAH): only JIVAH in the switcher, no OLIU anywhere
The owner sees across all companies	MD and Reporting Officer have `companyId = null`	Sign in as Eraste: switcher with OLIU and JIVAH
A suspended person is refused and the attempt is kept	`identity/routes.ts` login → `login_refused` audit row	Try Charles Mwakasege
History cannot be edited or deleted, by anyone	a database trigger on `AuditEvent` refuses UPDATE and DELETE	Test "the audit table refuses UPDATE and DELETE"
The browser is never trusted	the web app only displays what `/api/auth/me` returns; menus, permissions and company lists come from the API	Change nothing in the browser, the API still decides

3. How a request travels through the code

Take "Aline, Finance Officer at OLIU, opens User management".

1. The browser calls `GET /api/users` with the session cookie. Nuxt proxies it to the API.
2. `attachSession` (api/src/middleware/auth.ts) reads the cookie, checks its signature, loads the session and the user. It builds a **Scope**: `{ accountId, userId, role: FINANCE_OFFICER, companyId: OLIU }`.
3. The route (api/src/modules/accounts/routes.ts) asks `requireAuth`, then queries users `where accountId = scope.accountId and (companyId = OLIU or companyId = null)`. The filter comes from the scope, never from anything Aline typed.
4. The answer is a list of OLIU people and the all-company people. JIVAH's staff are not in it.

Take "Eraste invites Charles as JIVAH Finance Officer".

1. `POST /api/users` with name, e-mail, role, company. `requirePermission('users')`: only the MD passes.
2. The route checks the company belongs to the account and that the role needs a company.
3. In one transaction: the user row is created with status `INVITED`, an audit row `user_invited` is written.

4. A one-use link is e-mailed (in development it lands in `http://localhost:3001/dev/mail`).
5. Charles opens the link, chooses a password, becomes `ACTIVE`. Audit row `password_set`.

4. Folders, so you can find things

```
shared/src/index.ts           the vocabulary: six roles, their permissions and screens,
packages, stages,
                              the set-up questions (validation rules), company kinds
api/src/config.ts             reads .env once, refuses to start if something is missing
api/src/db.ts                 the database client and the scope helpers (byAccount,
byCompany)
api/src/middleware/auth.ts    who is calling; requireAuth / requireRole /
requirePermission
api/src/lib/                  audit, crypto (hashing, signing), mail, errors, validation
api/src/modules/identity/     login, one-time code, logout, me, set-password, forgot
api/src/modules/accounts/     create account, companies, bank accounts, people
api/src/modules/audit/        read the trail
api/src/modules/dev/          development inbox (never in production)
api/prisma/schema.prisma      the tables; migrations/ holds the SQL that created them
api/prisma/seed.ts            the OLIU · JIVAH demo account with twelve people
api/test/slice1.test.ts       the roadmap's tests as code
web/pages/                    login, setup, set-password, forgot, app/[screen]
web/components/Screen*.vue    the three built screens
web/layouts/app.vue           the sidebar built from what the API says the role may open
```

5. Try it yourself

```
npm run db:start      (keep this window open)
npm run db:migrate
npm run db:seed
npm run dev:api       (second window)
npm run dev:web       (third window)
```

Open http://localhost:3000. Password for every demo person: `demo`. The six-digit code is at http://localhost:3001/dev/mail (nothing leaves your machine in development).

SIGN IN AS	E-MAIL	WHAT YOU SHOULD SEE
Eraste K., MD	eraste.k@oliulogistics.rw	all ten menus, the switcher with OLIU and JIVAH, 12 people, the audit trail
Samuel Nyerere, Ops Manager JIVAH	samuel.n@jivahlogistics.co.tz	nine menus, no switcher, JIVAH only
Aline Uwase, Finance Officer OLIU	aline.u@oliulogistics.rw	Home, Payments, Invoices, Accounting, Reports, Notifications
Peace Kayitesi, Field Officer	peace.k@oliulogistics.rw	Shipments, Field payments, Notifications; cannot open the audit trail
Claire Irakoze, Reporting Officer	claire.i@oliulogistics.rw	read-only banner; audit trail readable
Charles Mwakasege	charles.m@jivahlogistics.co.tz	refused: suspended. Reactivate him as Eraste, then he can sign in

Then as Eraste: invite someone, open the dev inbox, follow the link, set a password, sign in as them. Try `/setup` to create a second, single-company account: it will have one company and no switcher.

6. Your test road — seven runs, tick each one

Password for every demo person: `demo`. Codes land in http://localhost:3001/dev/mail (refresh it).

#	RUN	SIGN IN AS	WHAT MUST HAPPEN	✓
1	The owner	eraste.k@oliulogistics.rw	All ten menus · switcher with OLIU and JIVAH · badge "all companies" · User management shows 12 people, Charles suspended · Company & subscription shows two companies, OLIU bills the client, five OLIU bank accounts · Audit trail's top row is your own login	☐
2	The other side	samuel.n@jivahlogistics.co.tz	No switcher · badge JIVAH LOGISTICS LTD · nothing of OLIU anywhere · Shipments says "slice 2"	☐
3	Finance	aline.u@oliulogistics.rw	Only Home, Payments, Invoices, Accounting, Reports, Notifications · no Settings, no Checks	☐
4	The field	peace.k@oliulogistics.rw	Three menus only · typing `/app/aud` in the address bar says the screen is not visible to your role	☐
5	Suspension	charles.m@jivahlogistics.co.tz	Sign-in refused with the suspension message · as Eraste, the refused attempt is in the Audit trail · Reactivate him in User management · Charles can now sign in	☐
6	Invite someone	Eraste → a new person	Invite by e-mail (any name, e-mail, role, company) · the invitation link is in the inbox · set a password · sign in as that person · Eraste's Audit trail shows user invited, password set, login	☐
7	A new single-company client	http://localhost:3000/setup	Create an account with one company and yourself as owner · sign in · one company, no switcher	☐

Pass when all seven are ticked and nothing looked wrong, slow or confusing, wording included. Note: the login limit is 20 attempts per 15 minutes from one address; if you hit it, the API is restarted.

What your run of 23 October left in the audit trail

You went down the road from 20:02 to 20:10. The trail (which nobody can edit) shows:

#	SEEN IN THE TRAIL	STILL TO DO
1	Eraste signed in at 20:06 and 20:09	tick it if the four screens looked right
2	Samuel signed in at 20:02	—
3	Aline signed in at 20:03	—
4	Peace signed in at 20:04	—
5	Charles refused at 20:05, the refusal is in the trail	Charles was never reactivated; he is still suspended. Reactivate him, then sign in as him
6	Eraste invited "Eric" (me.m@jivahlogistics.co.tz, Field Officer, OLIU) at 20:08, then suspended him 19 seconds later	The invitation link was never opened. Reactivate Eric (or invite someone else), open the link in the dev inbox, set a password, sign in
7	nothing: no second account was created	create one from /setup
extra	Jean Habimana (Transport Coordinator) and Claire Irakoze (Reporting Officer) also signed in	—

Two things to look at when you continue: Eric's e-mail is at the JIVAH domain but he was placed in OLIU, which is allowed but worth a glance; and if you saw "Something went wrong on our side" at any point before the end, that was the database fault of section 9, not something you did.

7. What was tested, and how

Fourteen automated tests run against a fresh database on every `npm test` (about 13 seconds):

- Account set-up creates main, partner and branch companies and the owner as MD; refuses a group with no partner, two billers, or a branch without a parent.
- Login mails a six-digit code to the department mailbox; a wrong code is refused; a forged cookie is refused; a wrong password and an unknown e-mail get the same answer (nothing to learn from the difference).
- A JIVAH Finance Officer never sees the OLIU company, even when asking for it by name; the MD sees every company.
- The switcher accepts only a company of the same account (another account's company: 403).
- A Finance Officer cannot invite; the MD can; a company-bound role must be given a company.
- A single-company account has one company and no partner.
- Suspension: the session dies, the next login is refused, the refusal is in the trail, the MD can reactivate.
- The audit table refuses UPDATE and DELETE at database level.
- A Field Officer cannot read the trail; a Reporting Officer can, with no write permissions.
- The local database keeps serving after it has dropped more clients than it has connection slots, and after a query has failed inside it (the two faults of section 9).

Also done by hand through the running web app: the six logins above, the switcher guard, the people list, the audit trail, the dev inbox.

Security checklist for this slice: passwords hashed with argon2id · codes and link tokens stored only as hashes · session cookie httpOnly, signed, SameSite · rate limits on login, code and set-up · every input validated with a schema · every query parameterised by Prisma · secrets only in `.env` · helmet headers · errors never leak internals · dependencies pinned.

8. What was deliberately left out

- No bookings, containers, money. Slice 2 starts the container.
- No four-eyes on bank account changes yet (the fields exist; the rule arrives with Payments, slice 6).
- Feature switches are stored but have no screen; they get one in the owner portal.
- No owner portal: the account is created from `/setup`, which is the same set-up form the tenant keeps.
- Nothing is sent by real e-mail or SMS yet; development keeps mail on the machine. Production needs an SMTP account.

9. Two things that changed on the way

- **Docker is not installed on this machine, and the application-control policy blocks native PostgreSQL binaries.** Development therefore runs PGlite: real PostgreSQL compiled to WebAssembly, served on a port so Prisma talks to it normally. The server will use ordinary PostgreSQL from `docker-compose.yml`; nothing in the code knows the difference. Hosting in Kigali is unchanged.
- **What stopped your test on 23 October.** The library that puts PGlite on a port (`pglite-socket` 0.2.14) has two faults. Every client it drops, for being silent for 30 seconds or for vanishing, keeps its connection slot for ever; with 8 slots, the eighth pause of your test used the last one, and from then on every request got "Something went wrong on our side" while the pages themselves still opened. And a query that fails inside the library freezes everything queued behind it. Both are now guarded in `api/scripts/local-postgres.ts` (no silent-client timeout, 16 slots, dropped clients are forgotten, a failed query no longer freezes the queue), and a test proves each guard. The server's real PostgreSQL has neither fault; this only ever concerned development on this machine. The database now runs in its own PowerShell window titled "OLIU db:start"; if it ever looks stuck again, close that window and run `npm run db:start`.

10. Questions for you

1. The **department mailboxes** (management@, ops@, finance@, transport@, reports@ for OLIU; the same for JIVAH) must exist before slice 1 can be tested with real e-mail. Who creates them, and by when?

2. The Reporting Officer is **all-company** in the old mockup. Keep that, or make it a per-company role too?
3. The demo seed names people from the mockup. Give me the **real list of twelve** (name, e-mail, role, company) when you have it and the seed becomes the real first load.